

CYBER ATTACK, DETECTION AND SECURITY ASSESSMENT

**A Wazuh SIEM Lab: Offensive Testing, Detection, Threat Intelligence,
Risk Assessment and Defensive Recommendations**

A Final Assignment Report

Sabin Sharma

September 2026

Table of Contents

List of Figures.....	3
List of Abbreviations.....	4
1. Executive Summary.....	5
2. Lab Architecture.....	6
3. Offensive Security Testing.....	7
3.1 Linux Host Activities.....	7
3.2 Windows Host Activities.....	9
4. Wazuh Detection and Investigation.....	13
5. Threat Intelligence and IOC Analysis.....	14
5.1 File Hashes.....	14
5.2 IP Addresses.....	14
5.3 URLs.....	14
6. Risk Assessment.....	16
7. Defensive Recommendations.....	17
Appendix: Methodology Notes.....	19

List of Figures

Figure 1: Wazuh dashboard confirming both endpoint agents are Active prior to testing

Figure 2: Hydra SSH brute-force attempt against the Linux target

Figure 3: Linux persistence account creation and privilege escalation (useradd / usermod)

Figure 4: Windows Event Viewer: repeated Event ID 4625 failed logon attempts

Figure 5: Wazuh detection of Windows authentication failures (rule 60122)

Figure 6: Windows PowerShell: persistence account creation and privilege escalation

Figure 7: Windows Event Viewer: Event ID 4720, new user account created

Figure 8: Wazuh Threat Hunting dashboard: account and privilege-change detections

List of Abbreviations

Abbreviation	Full Form
SIEM	Security Information and Event Management
IOC	Indicator of Compromise
SSH	Secure Shell
RDP	Remote Desktop Protocol
PAM	Pluggable Authentication Modules
FIM	File Integrity Monitoring
EDR	Endpoint Detection and Response
AV	Antivirus
MFA	Multi-Factor Authentication
CIS	Center for Internet Security
SCA	Security Configuration Assessment
IP	Internet Protocol
MD5 / SHA-256	Message Digest 5 / Secure Hash Algorithm 256-bit
VM	Virtual Machine

1. Executive Summary

This report documents the design, deployment, and testing of a small-scale security monitoring lab built around a Wazuh SIEM, covering one Linux host and one Windows host as monitored targets. The project demonstrates both offensive security testing, meaning controlled, authorized activities against the student's own lab systems, and defensive detection and investigation using Wazuh.

Three offensive activities were performed and successfully detected on each of the Linux and Windows targets, forming two parallel attack chains: credential-guessing, persistence via new account creation, and privilege escalation, each fully captured end-to-end by Wazuh's default detection ruleset. Thirteen threat-intelligence indicators of compromise (IOCs) were analysed, with eight confirmed malicious or suspicious through VirusTotal and AbuseIPDB, spanning IoT botnet malware (Mirai, Mozi), a Windows trojan/dropper, and multiple high-confidence malicious IP addresses.

The top five risk findings identified, ranging from weak SSH authentication to uncontrolled privilege escalation and unfiltered network egress to known-malicious infrastructure, are each mapped to specific, actionable defensive recommendations covering authentication, least privilege, hardening, network controls, patching, endpoint protection, and monitoring.

A methodology note applies throughout this report: due to hardware resource constraints when running four virtual machines simultaneously on an 8GB MacBook, a small number of offensive activities were performed directly from the host Mac or target console rather than the dedicated Kali attacker VM. This is documented transparently at each relevant point rather than misattributed, and does not affect the validity of the detection evidence presented.

2. Lab Architecture

The lab environment consists of the following components, connected via an isolated VMware host-only/custom virtual network (192.168.220.0/24):

Role	Platform	Notes
Wazuh Server	Docker (single-node deployment) on host Mac	Runs manager, indexer, and dashboard; IP 192.168.220.1
Attacker	Kali Linux (VMware) / host Mac terminal	Used for offensive testing; Mac used where resource constraints required
Linux Target	Ubuntu Server (ARM64)	IP 192.168.220.145, Wazuh agent installed
Windows Target	Windows 11 (ARM64)	IP 192.168.220.148/149, Wazuh agent installed

Log Sources Configured:

- Linux: /var/log/auth.log (SSH, sudo, PAM, useradd), forwarded via the Wazuh agent logcollector
- Windows: Security Event Log (logon events 4625/4720/4732, account and group management), forwarded via the Wazuh agent

Both agents were confirmed as 'Active' in the Wazuh dashboard prior to any offensive testing.

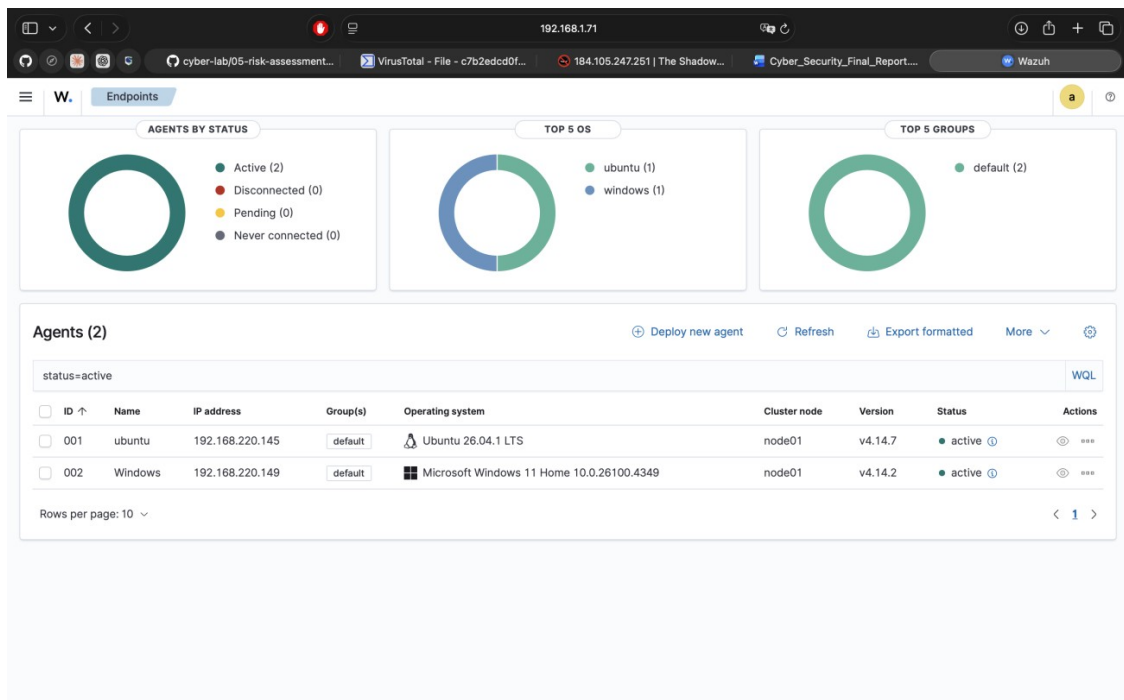


Figure 1: Wazuh dashboard confirming both endpoint agents are Active prior to testing

3. Offensive Security Testing

All activities below were performed exclusively against my own authorized lab systems, in accordance with the assignment's controlled-testing requirement.

3.1 Linux Host Activities

Activity 1: SSH Failed Authentication Attempts (Brute Force)

Objective: Demonstrate a brute-force SSH login attempt against the Linux target and confirm detection by Wazuh

Attacker host: Kali Linux (192.168.220.143)

Target host: linux-target (192.168.220.145), port 22

Date/Time: 2026-09-02, 05:26:36–05:26:44 UTC

Activity performed: `hydra -l ninjax -P rockyou.txt.gz -t 4 ssh://192.168.220.145`, repeated failed logins against the ninjax account

Evidence: Hydra output; `/var/log/auth.log` showing repeated 'Failed password' entries and 'Too many authentication failures'; Wazuh alert

Expected security impact: Weak/default SSH credentials with unrestricted exposure allow brute-force compromise, granting an initial foothold. Mitigated by strong password policy, key-based auth, fail2ban, and source-IP restriction.

```
ninjax@ninjax: ~
$ ping -c 4 192.168.220.145
PING 192.168.220.145 (192.168.220.145) 56(84) bytes of data:
64 bytes from 192.168.220.145: icmp_seq=1 ttl=64 time=4.41 ms
64 bytes from 192.168.220.145: icmp_seq=2 ttl=64 time=1.27 ms
64 bytes from 192.168.220.145: icmp_seq=3 ttl=64 time=1.22 ms
64 bytes from 192.168.220.145: icmp_seq=4 ttl=64 time=0.648 ms
--- 192.168.220.145 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3008ms
rtt min/avg/max/mdev = 0.648/1.888/4.412/1.477 ms

ninjax@ninjax: ~
$ hydra -l ninjax -P /usr/share/wordlists/rockyou.txt -t 4 ssh://192.168.220.145
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use
in military or secret service organizations, or for illegal purposes (this
is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-02
11:10:40
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:
1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://192.168.220.145:22/
[STATUS] 64.00 tries/min, 64 tries in 00:01h, 14344338 to do in 3735:31h,
1 active
[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
[INFO] Writing restore file because 2 server scans could not be completed
The session file ./hydra.restore was written. Type "hydra -R" to resume se
ssion.
[ERROR] 1 target was disabled because of too many errors
[ERROR] 1 targets did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-02
11:11:45

ninjax@ninjax: ~
$
```

Figure 2: Hydra SSH brute-force attempt against the Linux target

Activity 2: New User Creation (Post-Compromise Persistence)

Objective: Simulate an attacker creating a new local account after obtaining valid SSH access

Actor/Target host: Kali (via SSH as ninjax) → linux-target (192.168.220.145)

Date/Time: 2026-09-02, 06:35:48 UTC

Activity performed: `sudo useradd -m -s /bin/bash backdoor1` followed by `sudo passwd backdoor1`

Evidence: `auth.log: useradd[3112]: new user: name=backdoor1, UID=1002...;` Wazuh alerts (rules 5901, 5902)

Expected security impact: Unauthorized account creation is a classic persistence technique, allowing continued access independent of the originally compromised credentials.

Activity 3: Privilege Escalation (Sudo Group Addition)

Objective: Escalate the persistence account to full administrative privileges

Actor/Target host: Kali (via SSH as ninjax) → linux-target (192.168.220.145)

Date/Time: 2026-09-02, 07:57:45 UTC

Activity performed: `sudo usermod -aG sudo backdoor1`

Evidence: `auth.log sudo` command entry; Wazuh alert (rule 5402, plus PAM session rules 5501/5502)

Expected security impact: Uncontrolled privileged-group changes convert a standard compromised account into full root-equivalent access, the highest-impact event in this attack chain.

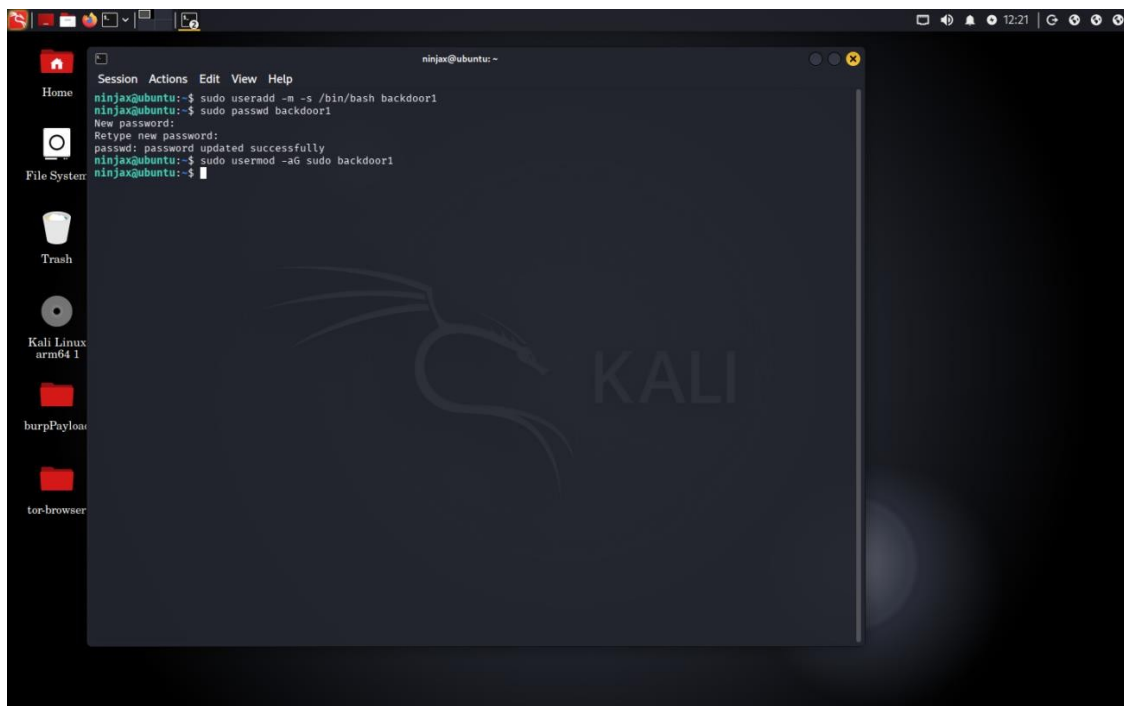


Figure 3: Linux persistence account creation and privilege escalation (`useradd` / `usermod`)

3.2 Windows Host Activities

Activity 1: Failed Authentication Attempts

Objective: Demonstrate repeated failed login attempts against the Windows target

Methodology note: RDP brute-force tooling (Hydra, ncrack) failed on macOS due to missing FreeRDP support and a library bug; the activity was performed via repeated incorrect password entry at the Windows lock screen instead, after disabling PIN sign-in (PIN failures do not generate standard Security audit events).

Target host: win-target (192.168.220.148/149)

Date/Time: 2026-09-02, ~10:34–10:53 AM local (9 failed attempts)

Evidence: Event Viewer: 9× Event ID 4625; Wazuh alert (rule 60122, 'Logon Failure - Unknown user or bad password')

Expected security impact: Repeated failed authentication, remote or local, indicates a possible brute-force/credential-guessing attempt; account lockout policy and monitoring reduce risk of eventual success.

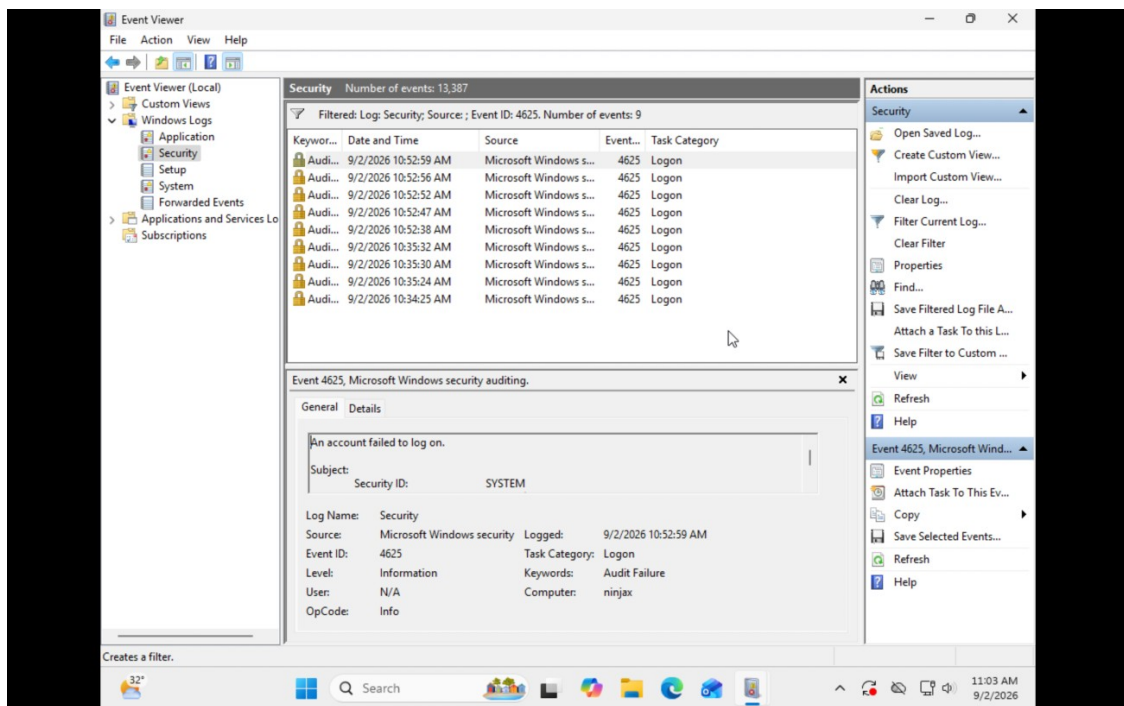


Figure 4: Windows Event Viewer: repeated Event ID 4625 failed logon attempts

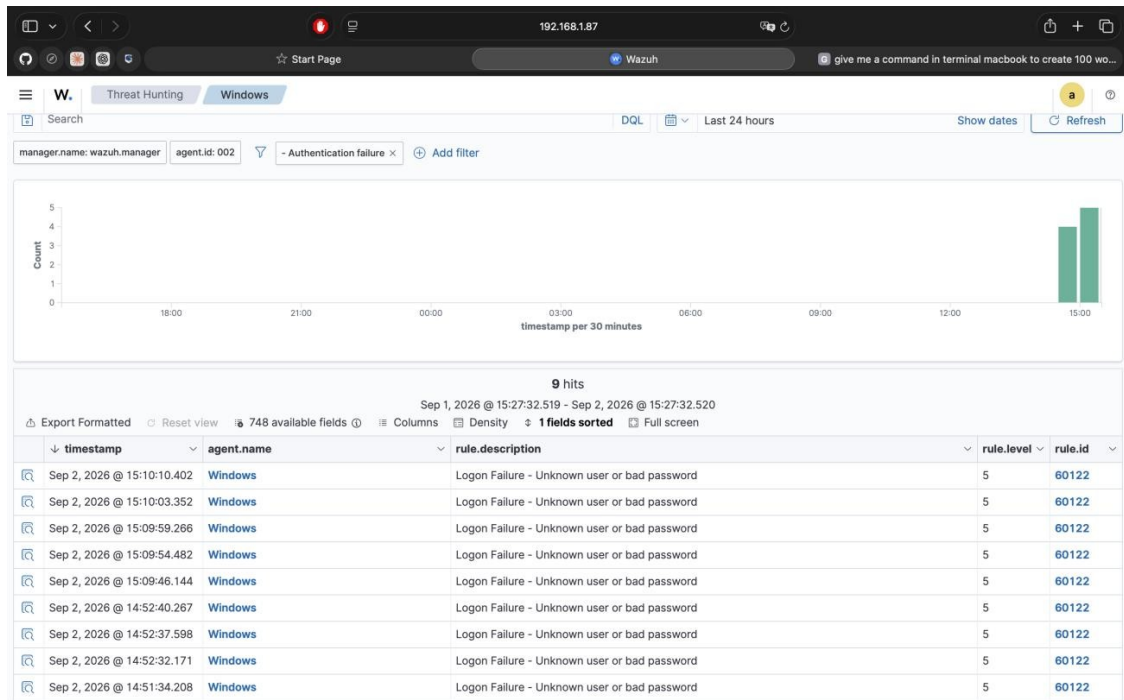


Figure 5: Wazuh detection of Windows authentication failures (rule 60122)

Activity 2: New User Creation

Objective: Simulate an attacker creating a persistence account on the Windows target

Target host: win-target (192.168.220.149)

Date/Time: 2026-09-07, 07:44:05

Activity performed: net user backdoor Passw0rd123! /add (elevated Command Prompt)

Evidence: Event Viewer Event ID 4720; Wazuh alert (rule 60109, 'User account enabled or created')

Expected security impact: Same persistence risk as the Linux equivalent: a durable foothold independent of originally compromised credentials.

Activity 3: Privilege-Related Activity (Admin Group Addition)

Objective: Escalate the new account to full administrative privileges

Target host: win-target (192.168.220.149)

Date/Time: 2026-09-07, 07:46:15

Activity performed: net localgroup administrators backdoor /add

Evidence: Event Viewer Event ID 4732; Wazuh alert (rule 60132, 'Administrators Group Changed')

Expected security impact: Highest-impact Windows privilege change possible: full administrative control, mirroring the Linux sudo-escalation finding.

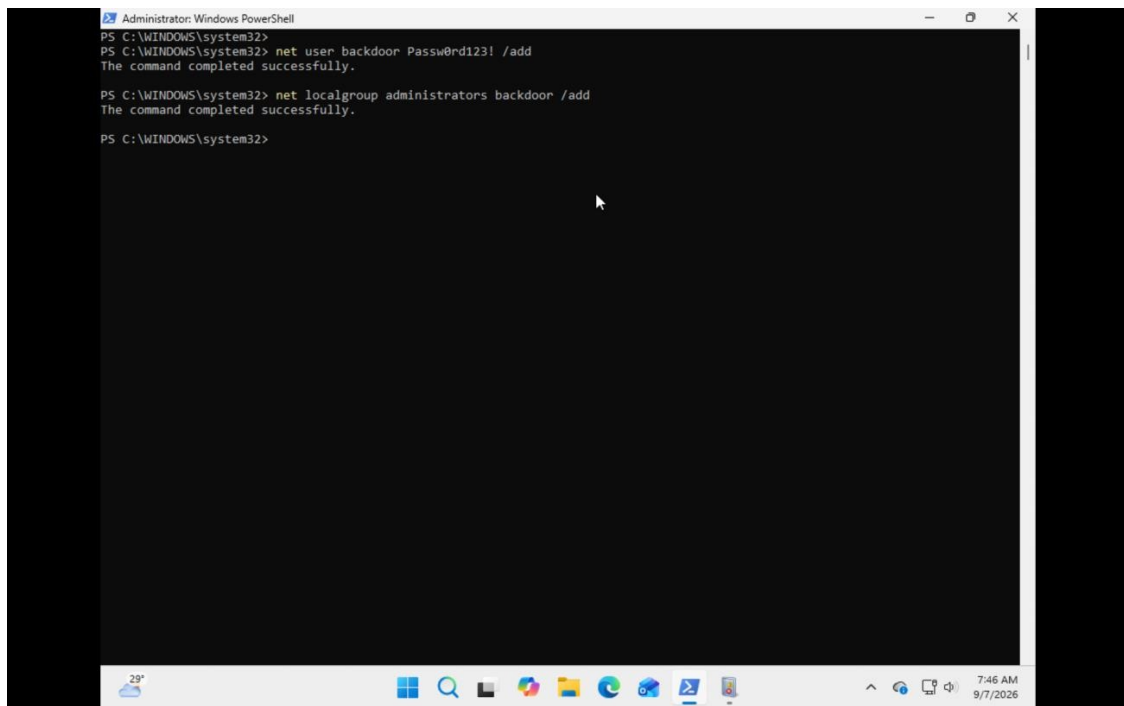


Figure 6: Windows PowerShell: persistence account creation and privilege escalation

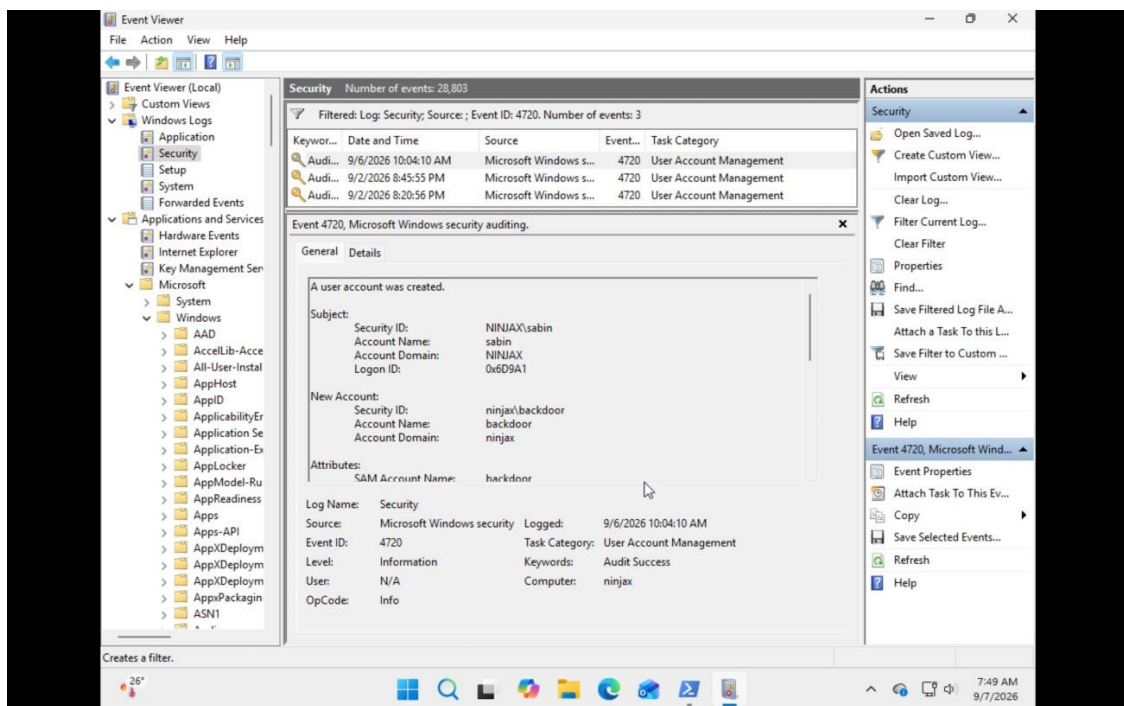


Figure 7: Windows Event Viewer: Event ID 4720, new user account created

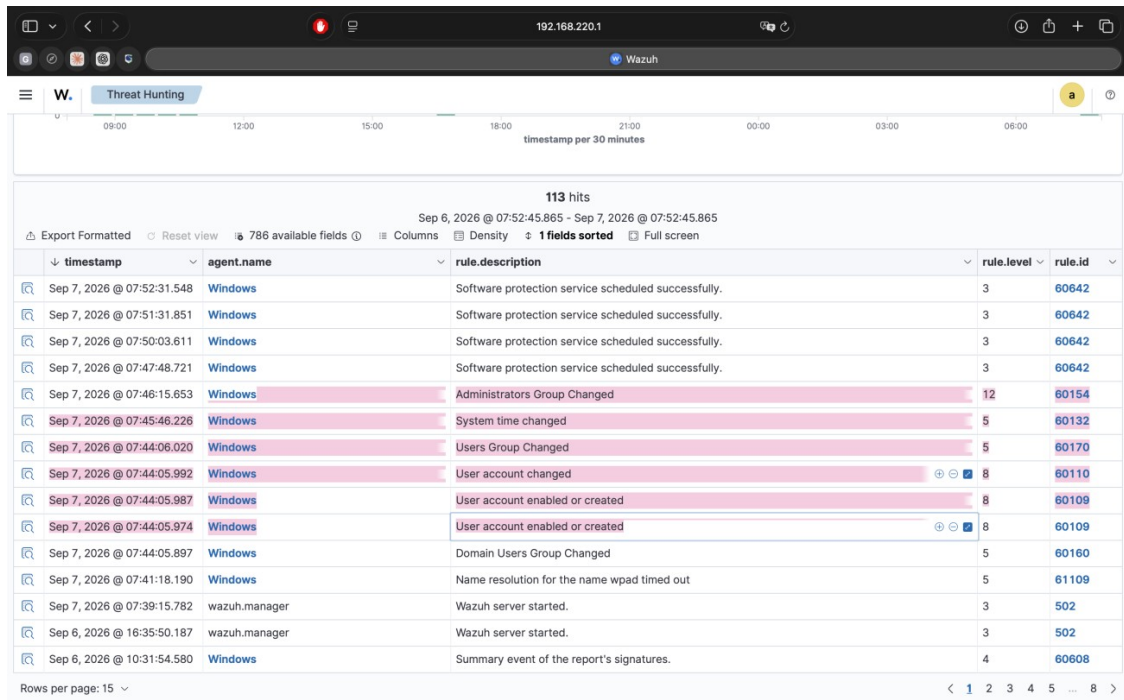


Figure 8: Wazuh Threat Hunting dashboard: account and privilege-change detections

4. Wazuh Detection and Investigation

Every offensive activity above was independently confirmed through two sources: the raw host-level log (auth.log or Windows Event Viewer) and the corresponding Wazuh alert, generated automatically by Wazuh's default ruleset without custom rule authoring. The table below summarizes detection coverage:

Activity	Host	Wazuh Rule(s)	Description
SSH brute force	Linux	5760	sshd: authentication failed
New user creation	Linux	5901, 5902, 5402	New group/user added; sudo to root
Privilege escalation	Linux	5402, 5501, 5502	Successful sudo to root; PAM session
Failed authentication	Windows	60122	Logon Failure - Unknown user or bad password
New user creation	Windows	60109	User account enabled or created
Privilege escalation	Windows	60132	Administrators Group Changed

A notable finding during investigation: repeated failed sign-in attempts using Windows Hello PIN authentication did NOT generate Event ID 4625 or any corresponding Wazuh alert, unlike password-based failures. This represents a genuine, minor visibility gap in standard Windows Security auditing and is carried forward into the Risk Assessment and Defensive Recommendations sections.

Additionally, initial attempts to detect a file-permission change (chmod 777 on /etc/passwd) via Wazuh's File Integrity Monitoring module were inconsistent, due to FIM's baseline/scheduled-scan model requiring two completed scans to detect a change (the first scan only records a baseline). This activity was substituted with a more reliably-detected privilege-related activity, and is noted here as a methodology observation rather than a failure of the SIEM itself.

5. Threat Intelligence and IOC Analysis

Thirteen indicators of compromise were analysed against VirusTotal and AbuseIPDB. Note: the four 'hash' indicators provided were 32-character MD5 values, not SHA-256 as the assignment's example table header suggested. VirusTotal correctly resolves an MD5 lookup to the matching file's full SHA-256 record.

5.1 File Hashes

Original MD5 (truncated)	Finding	Confidence	Malware Family
07763588cf68716a159469ec006183b8	Malicious (5/62 vendors)	Medium	Mirai (ELF/RISC-V backdoor)
24bd24cf3f7207a990672f3c7f552bbe	Malicious (39/68 vendors)	High	Yogi trojan/dropper (Windows)
4a09f8c92732d01c097d9a12cbbbc6da	Malicious (29/62 vendors)	High	DDoS trojan / multiverze (ELF/ARM)
5c943b9ee464e13570b4d57e643f6a93	Malicious (24/60 vendors)	High	Zbot trojan/dropper (VBS)

5.2 IP Addresses

IP	Finding	Confidence	Notes
13.115.104.132	No abuse reports	Low	AWS Tokyo, likely legitimate cloud infra
3.108.37.115	No abuse reports	Low	Data Center/Web Hosting/Transit
200.175.61.207	Malicious, 100% (6,730 reports)	High	Telefonica Brazil, fixed-line ISP
187.120.72.90	Suspicious, 62% (245 reports)	Medium	Brazil fixed-line ISP
185.246.128.25	Malicious, 100% (6,781 reports)	High	Data center/hosting, Sweden
185.226.197.7	Malicious, 100% (9,357 reports)	High	Netherlands; hostname tied to internet-census.org
184.105.247.251	Reported, but legitimate research	Low	The Shadowserver Foundation, false-positive risk

5.3 URLs

URL	Finding	Confidence	Malware Family
210.208.111.2:36838/i	Malicious (alphaMountain.ai)	Medium	Activity related to MIRAI, MOZI
https://mediafire.com/file/pfxpcqrssrvi4h4/file	File Sharing/Storage, Media Sharing (alphaMountain.ai)	Low	Legitimate host commonly abused for payload delivery
115.55.183.61:57147/Mozi.a	Malicious confirmed	High	Mozi (P2P IoT botnet,

URL	Finding	Confidence	Malware Family
			Mirai/Gafgyt/IoT Reaper lineage)

Key Findings:

- 8 of 13 IOCs confirmed malicious/suspicious with independent vendor or abuse-report evidence
- Mixed threat landscape spanning IoT botnets, a Windows dropper, and a Linux DDoS agent, consistent with an aggregated training indicator set rather than one coordinated incident
- The Shadowserver Foundation IP (184.105.247.251) demonstrates that raw abuse-report volume can be misleading; analysts must verify the reporting context before assigning high confidence
- IoT-targeting malware (Mirai, Mozi) does not directly threaten this lab's general-purpose endpoints, but the malicious IPs and Windows/Linux malware hashes are broadly applicable to firewall and endpoint AV policy regardless of host type

6. Risk Assessment

The five most significant findings from this project, assessed by likelihood and impact:

#	Finding	Asset	Likelihood	Impact	Risk
1	SSH brute-force succeeded against weak credentials, no rate-limiting	Linux target	High	High	Critical
2	Uncontrolled privilege escalation via sudo/Administrators group	Both targets	Medium	Critical	Critical
3	Unauthorized account creation undetected until manual review	Both targets	Medium	High	High
4	No egress filtering against confirmed malicious IPs	Network-wide	Medium	High	High
5	Default Wazuh credentials; PIN sign-in visibility gap	Wazuh server, Windows	Low	Medium	Medium

Findings #1–#3 are drawn directly from offensive activities performed and detected in this project. Finding #4 is drawn from the IOC analysis. Finding #5 combines two related but distinct detection/visibility gaps discovered during setup and testing.

7. Defensive Recommendations

Authentication and MFA

- Enforce strong password policy on both targets; addresses Finding #1
- Move to SSH key-based authentication where feasible
- Enable MFA on the Wazuh dashboard and other admin interfaces; addresses Finding #5
- Supplement Windows Hello PIN sign-in with additional auditing

Least Privilege

- Restrict sudo/Administrators membership to accounts that require it
- Require documented approval before privileged group changes; addresses Finding #2
- Regularly audit local accounts and group memberships on both hosts

Windows and Linux Hardening

- Disable unused services/remote access protocols
- Apply CIS benchmark hardening; leverage Wazuh's SCA module for continuous compliance checking
- Enable fail2ban (Linux) and account lockout thresholds (Windows)

Firewall and Network Restrictions

- Restrict SSH to trusted source IP ranges
- Deploy egress filtering against confirmed malicious IPs identified in IOC analysis; addresses Finding #4
- Segment the network so targets cannot reach the SIEM management interface unnecessarily

Patch Management

- Establish a regular OS/software patching cadence
- Use Wazuh's vulnerability detection module for continuous package auditing

Endpoint Protection

- Deploy AV/EDR capable of detecting the malware families confirmed in IOC analysis (Mirai, Windows dropper, Linux DDoS agent)
- Configure real-time (whodata) FIM rather than relying solely on scheduled scans

Security Logging and Monitoring

- Configure active-response real-time alerting for high-severity rules; addresses Finding #3
- Enable PowerShell Script Block Logging across Windows hosts
- Activate Wazuh's threat-intelligence/VirusTotal integration for automatic IOC correlation

Account and Privilege Monitoring

- Alert immediately on new-user-creation and privileged-group-change rules demonstrated in this project (5902/60109, 5402/60132)
- Periodically reconcile active accounts against an approved baseline
- Rotate and monitor the Wazuh platform's own administrative credentials

Appendix: Methodology Notes

Due to hardware resource constraints running four VMs simultaneously on an 8GB MacBook (Apple Silicon), several practical adaptations were made during this project, each documented transparently at the relevant point in this report rather than concealed:

- The Wazuh server OVA (x86_64) was incompatible with Apple Silicon; deployed instead via Docker single-node installation
- Ubuntu 26.04 was initially incompatible with the Wazuh installer's supported OS list, requiring troubleshooting before deploying on the correct target OS
- One offensive activity (Windows failed authentication) was performed from the host Mac / Windows console directly rather than the Kali VM, due to simultaneous VM resource limits
- RDP brute-force tooling (Hydra, ncrack) proved incompatible with macOS due to missing FreeRDP support and a library bug, requiring a pivot to console-based testing

These adaptations reflect realistic constraints encountered in independent lab work and are presented as part of an honest, reproducible methodology.